

Caso De Estudio Forense: Operación "SHADOW VAULT"

Carolina Salinas
David Mora Fierro
Juan Nikolas Hernández
Johana Iden Lambuley Contreras

Jaider Ospina

Maestría En Ciberseguridad y Ciberdefensa

Escuela Superior de Guerra "General Rafael Reyes Prieto"
Bogotá D.C., Colombia
2026

CASO DE ESTUDIO FORENSE: OPERACIÓN "SHADOW VAULT"

Análisis Crítico Articulado: NIST SP 800-86 e ISO/IEC 27042:2015

1. DESCRIPCIÓN DEL INCIDENTE

Contexto Institucional e Infraestructura Comprometida

El incidente ocurrió en la entidad financiera multinacional *Financiera Andina S.A.*, con sede operativa en Bogotá. El entorno afectado comprende el segmento de servidores críticos (DMZ interna y Core Bancario):

- **Servidor de Base de Datos Transaccional (**`DB-CORE-01`**):** Servidor físico HPE ProLiant DL380 Gen10, SO Red Hat Enterprise Linux 8.8, motor Oracle Database 19c Enterprise. Almacena las tablas de cuentas de ahorros, saldos y órdenes de pago internacionales vía SWIFT.
- **Controlador de Dominio (**`DC01-BOG`**):** Máquina virtual Windows Server 2022 alojada sobre un clúster VMware vSphere 7.0, encargado de la autenticación Kerberos y directivas de grupo (GPO).
- **Pasarela Perimetral y Enrutamiento:** Clúster de Firewalls perimetrales FortiGate 600E con inspección SSL/TLS profunda y registro de eventos enviado a un SIEM (Splunk Enterprise).

Cronología Fáctica de los Hechos (Tiempos Normalizados en UTC)

- **2026-09-14 23:15:10 UTC:** La cuenta de usuario del administrador de infraestructura `j.sarmiento` inicia sesión remota interactiva vía VPN SSL desde una dirección IP residencial de Bogotá (`190.27.112.45`), autenticándose mediante credenciales válidas y superando el segundo factor (MFA push aceptado en el dispositivo móvil corporativo).
- **2026-09-14 23:22:04 UTC:** Desde la sesión VPN establecida, se genera una conexión RDP hacia el servidor `DC01-BOG`. A través de este host, se abre una sesión SSH autenticada por llave RSA hacia el servidor `DB-CORE-01`.
- **2026-09-14 23:45:30 UTC:** En `DB-CORE-01` se invoca un script denominado `export_trans.sh`, el cual ejecuta la utilidad `expdp` (Data Pump de Oracle) para generar un dump de 42 GB (`trans_sep2026.dmp`) correspondiente a transacciones interbancarias del último mes.

- **2026-09-15 01:10:15 UTC:** El archivo exportado se comprime y cifra utilizando `7za` con el nombre `backup_tmp.dat` en el directorio `/var/tmp/`.
- **2026-09-15 01:35:00 UTC:** Se inicia una transferencia de salida de alto volumen desde `DB-CORE-01` hacia un servidor externo con dirección IP pública `45.33.32.156` (nodo de salida registrado en un proveedor VPS en Linode/Akamai) mediante el protocolo SFTP sobre el puerto 2222.
- **2026-09-15 02:08:42 UTC:** El sistema de prevención de fugas de información (DLP) y el SIEM disparan una alarma crítica por exfiltración de datos al superar el umbral de 10 GB de tráfico saliente anómalo fuera del horario operativo.
- **2026-09-15 02:15:00 UTC:** El equipo de analistas de seguridad de guardia (SOC Nivel 1) ingresa a la sesión de `DB-CORE-01`, ejecuta comandos de inspección sin privilegios de auditoría (`w`, `top`, `ps -ef`, `kill -9 <PID_SFTP>`) y procede a **apagar físicamente el cable de energía del servidor** bajo la justificación de «frenar de inmediato el robo de información».
- **2026-09-15 06:30:00 UTC:** Se convoca al equipo de informática forense y respuesta a incidentes (DFIR) para recolectar la evidencia e investigar penalmente al funcionario `j.sarmiento` por presunto espionaje industrial y acceso abusivo a sistema informático.

Artefactos Disponibles para la Pericia

1. **Memoria Volátil (RAM):**
   - Servidor `DC01-BOG`: Captura de RAM completa (32 GB) adquirida en caliente previo al aislamiento.
   - Servidor `DB-CORE-01`: **No disponible** debido al corte de energía intempestivo ejecutado por el SOC Nivel 1.
2. **Imágenes Forenses de Disco:**
   - Archivo de imagen forense E01 del disco del sistema y volumen de datos de `DB-CORE-01` (Arreglo RAID-10 de 1.8 TB).
   - Snapshot forense (`.vmdk` congelado) del controlador de dominio `DC01-BOG`.
3. **Logs y Registros de Auditoría:**
   - Logs crudos del Firewall FortiGate exportados en formato Syslog (con tráfico de sesión, bytes transferidos y duración de sockets).
   - Eventos de seguridad de Windows (`Security.evtx`) de `DC01-BOG`.
   - Archivos de auditoría de Oracle Database (`.aud`) y log de transacciones de Linux (`/var/log/secure`, `/var/log/audit/audit.log`).

2. ANÁLISIS FORENSE APLICADO (METODOLOGÍA COMBINADA)

El procedimiento pericial se articuló combinando el enfoque técnico-operativo de **NIST SP 800-86** (adquisición, preservación y examen de artefactos) con el rigor analítico-

epistemológico de **ISO/IEC 27042:2015** (formulación de hipótesis, interpretación y contraste de falsación).

A. Fase Operativa de Preservación y Examen (Bajo NIST SP 800-86)

1. **Aislamiento y Triage Táctico:**
   - En `DC01-BOG` se mantuvo el sistema energizado pero aislado lógicamente de la red mediante la desconexión del conmutador virtual (vSwitch).
   - Aplicando la jerarquía de volatilidad (RFC 3227 / NIST SP 800-86 Sec. 3.1), se adquirió la memoria volátil utilizando `WinPmem 4.0` sobre un medio USB estéril, obteniendo el archivo `DC01-RAM.raw`.
2. **Adquisición No Volátil y Aseguramiento Criptográfico:**
   - Para `DB-CORE-01`, los discos físicos fueron extraídos y conectados a una estación pericial a través de un bloqueador de escritura por hardware *Tableau SAS/SATA Bridge*.
   - Se adquirió una imagen bit a bit en formato pericial *Expert Witness Format* (`DB-CORE.E01`).
   - **Protocolo de Hashing Dual:**
     SHA-256 (DB-CORE.E01) = 7c89f5a2...b412
     SHA-3/512 (DB-CORE.E01) = 9f01c3d8...a871

   - La imagen original se resguardó en la bóveda de evidencia digital y se generó una copia de trabajo montada en modo estricto de solo lectura (`mount -o ro,loop`).
3. **Examen y Filtrado de Datos (De-NISTing):**
   - Se redujo el espacio de búsqueda del sistema de archivos Linux mediante cotejo contra el catálogo NIST NSRL, excluyendo más de 180,000 archivos binarios legítimos de Red Hat.
   - Se aplicó *File Carving* en el espacio no asignado (`unallocated space`) y espacio holgado (`slack space`) de `/var/tmp/`, logrando recuperar fragmentos del script `export_trans.sh` que había sido eliminado con `rm -f`.

B. Fase Metodológica de Análisis e Interpretación (Bajo ISO/IEC 27042:2015)

Reconstrucción Temporal Unificada (Super-Timeline UTC)
Se procesaron los registros de auditoría mediante `plaso/log2timeline` y se cruzaron con las trazas de firewall:

```
[2026-09-14 23:15:10 UTC] | HOST: FortiGate   | Evento: Conexión VPN aceptada usuario 'j.sarmiento' (IP 190.27.112.45)
[2026-09-14 23:22:04 UTC] | HOST: DC01-BOG    | Evento: EventID 4624 (Logon Type 10 - RDP) usuario 'j.sarmiento'
[2026-09-14 23:24:18 UTC] | HOST: DC01-BOG   | Evento: Proceso 'mstsc.exe' spawn de PowerShell codificado en Base64
[2026-09-14 23:45:30 UTC] | HOST: DB-CORE-01 | Evento: Shell interactiva ejecuta 'export_trans.sh' -> expdp
```

```
[2026-09-15 01:10:15 UTC] | HOST: DB-CORE-01 | Evento: Ejecución de '7za a -p[REDACT] /var/tmp/backup_tmp.dat'
[2026-09-15 01:35:00 UTC] | HOST: FortiGate  | Evento: Inicio de flujo TCP puerto 2222 -> IP 45.33.32.156
[2026-09-15 02:08:42 UTC] | HOST: FortiGate  | Evento: Alarma SIEM DLP - Tráfico acumulado saliente: 11.8 GB
[2026-09-15 02:15:00 UTC] | HOST: DB-CORE-01 | Evento: Caída total de interfaz (Pérdida de energía / Shutdown súbito)
```

Formulación y Contraste de Hipótesis Periciales (Cláusula 8 - ISO 27042)
El informe preliminar de auditoría interna acusaba al ingeniero `j.sarmiento` de haber exfiltrado la totalidad de la base de datos por motivos económicos. El perito forense, dando cumplimiento a la mitigación del sesgo de confirmación y neutralidad probatoria, planteó tres hipótesis científicas rivales:

- **Hipótesis H1 (Acusación - Acción Deliberada del Empleado):** El funcionario `j.sarmiento` aprovechó sus credenciales legítimas para acceder al servidor, empaquetar la base de datos y exfiltrarla integralmente a un servidor externo bajo su control.
- **Hipótesis H2 (Compromiso Remoto - Malware / Actor Externo):** La estación de trabajo de `j.sarmiento` fue vulnerada previamente; un atacante externo capturó su token de sesión/credenciales y ejecutó comandos automatizados sin intervención del empleado.
- **Hipótesis H3 (Transferencia Incompleta / Frustrada):** Con independencia del autor, la exfiltración de los datos no se completó debido a la interrupción abrupta de la conexión.

Pruebas de Falsación y Evaluación de Evidencia:

1. **Contraste de H1 vs. H2:**
    - Al examinar la memoria RAM de `DC01-BOG` (`DC01-RAM.raw`) mediante Volatility 3, el plugin `windows.pstree` reveló que a las 23:24:18 UTC, la sesión RDP de `j.sarmiento` ejecutó un subproceso anómalo `cmd.exe` que invocó un script ofuscado de PowerShell.
    - El plugin `windows.malfind` detectó inyección de código correspondiente a un implante de **Cobalt Strike (Beacon)** que operaba como proxy SOCKS5 interno.
    - La geolocalización de las conexiones de control del Beacon apuntó a una dirección IP de infraestructura Tor.
    - **Conclusión sobre H1:** La hipótesis de dolo directo de `j.sarmiento` fue severamente debilitada; la evidencia técnica demostró que la estación del usuario actuó como pivote comprometido por un adversario externo mediante secuestro de sesión (*session hijacking*).
2. **Contraste de H3 (Volumen Exfiltrado vs. Volumen Generado):**
    - El archivo comprimido `backup_tmp.dat` en `/var/tmp/` tenía un tamaño final en disco de **34.2 GB** (constatado en los metadatos del sistema de archivos ext4 y logs de Oracle Data Pump).

- El log de flujo de tráfico del Firewall FortiGate consolidó que, desde el socket TCP abierto hacia `45.33.32.156:2222` hasta la desconexión del servidor a las 02:15:00 UTC, se transmitieron exactamente **11.8 GB** de datos.
- **Conclusión sobre H3:** La hipótesis H3 es **corroborada categóricamente**. La exfiltración fue parcial e incompleta. El atacante solo logró sustraer aproximadamente el 34.5% del archivo comprimido cifrado, lo que imposibilita la descompresión íntegra del archivo contenedor sin técnicas avanzadas de reconstrucción de archivos corruptos.

3. EVALUACIÓN CRÍTICA DE ADMISIBILIDAD PROBATORIA

A. Dictamen sobre la Solidez de la Evidencia Técnica

Bajo los criterios jurisprudenciales internacionales de admisibilidad científica (*Estándares Daubert y Frye*) y los códigos procesales:

- **Validez de las Imágenes de Disco e Integridad: PLENA Y ADMISIBLE.** Las imágenes E01 de `DB-CORE-01` y el volcado de `DC01-BOG` cumplen estrictamente con los requisitos de repetibilidad de **ISO/IEC 27042** y **NIST SP 800-86**. La coincidencia matemática de los hashes SHA-256 de origen y destino certifica que los datos no sufrieron mutación alguna desde el laboratorio forense.
- **Validez de los Registros Perimetrales (Firewall/SIEM): ADMISIBLE.** Los registros de tráfico cuentan con sincronización de tiempo mediante servidor local NTP stratum-2 y firmas de integridad dentro del repositorio centralizado Splunk WORM (*Write Once, Read Many*).

B. Análisis y Resolución de Fallas en la Cadena de Custodia y Procedimiento

Durante el análisis crítico del caso, la defensa técnica procesal impugnó la pericia señalando dos fallas metodológicas graves cometidas en la fase inicial:

Falla 1: Destrucción de Evidencia Volátil por Apagado Intempestivo

- **La Falla:** El equipo SOC Nivel 1 desconectó el cable de energía del servidor `DB-CORE-01` sin adquirir la memoria RAM, violando el orden de volatilidad estipulado en **RFC 3227** y **NIST SP 800-86 (Sección 3.1)**.
- **Impacto Probatorio:** Se perdieron de manera irreversible los procesos en memoria que ejecutaban el proceso SFTP, las conexiones de red no registradas en sockets duraderos y las claves simétricas de cifrado utilizadas por el comando `7za` para proteger el contenedor.
- **Resolución y Subsanación Forense (ISO 27042):**
  - El perito forense no intentó ocultar ni suponer lo que había en la memoria perdida, aplicando el principio de **declaración obligatoria de incertidumbre analítica**.

    - Para compensar la ausencia del volcado de RAM, se recurrió a fuentes secundarias de auditoría no volátil: el log transaccional del sistema operativo (`/var/log/audit/audit.log`) procesado por el demonio *auditd*, el cual registró de forma inmutable la llamada al sistema (*syscall*) `execve` con la sintaxis completa del comando ejecutado en la consola interactiva.
    - **Veredicto Judicial:** El tribunal desestimó la nulidad de toda la prueba, pero restringió el alcance de las conclusiones: no se pudo acusar al empleado del conocimiento de la clave de cifrado del malware, favoreciendo el principio de duda razonable (*in dubio pro reo*) respecto a su supuesta complicidad.

Falla 2: Ruptura Temporal en el Formato de Cadena de Custodia

- **La Falla:** El formulario físico de cadena de custodia del disco duro de `DB-CORE-01` registró la entrega del dispositivo por parte del oficial de seguridad física al perito forense a las **07:30 UTC**, pero la bitácora del laboratorio forense evidenció que el análisis inició a las **09:15 UTC**, sin registrar qué funcionario custodió el disco durante ese intervalo de 1 hora y 45 minutos dentro de las instalaciones.
- **Impacto Probatorio:** La contraparte alegó presunta manipulación, siembra de evidencia o ruptura de la cadena de custodia legal.
- **Resolución y Subsanación Criptográfica:**
    - La ruptura fue subsanada mediante el principio de **autenticación intrínseca de la evidencia digital**:
        1. Se demostró mediante los registros del sistema de control de acceso biométrico que el disco permaneció dentro de la sala de evidencias bajo llave durante ese periodo.
        2. Se certificó que el **Hash SHA-256 y SHA-3/512** calculado por el perito a las 09:15 UTC coincidía al 100% con el hash calculado por el duplicador forense autónomo en el momento exacto de la extracción física a las 06:45 UTC.
        3. Conforme a las directrices de **ISO/IEC 27042**, dado que una función hash resistente a colisiones tiene una probabilidad infinitesimal de colisión accidental (1 en 2^{256}), la identidad matemática de la prueba quedó demostrada más allá de toda duda razonable, neutralizando la tacha de alteración física.

4. CONCLUSIÓN Y DICTAMEN PERICIAL SINTETIZADO

1. **Sobre la Autoría del Hecho:** La evidencia técnica desvirtúa la acusación directa formulada contra `j.sarmiento`. Si bien sus credenciales de acceso fueron utilizadas, la memoria forense de `DC01-BOG` demostró la presencia activa de un implante Cobalt Strike operado remotamente por un tercero no identificado, el cual secuestró la sesión autenticada.

2. **Sobre el Daño y Exfiltración:** Se demostró mediante correlación de trazas de firewall y metadatos de almacenamiento que la exfiltración fue parcial (11.8 GB de 34.2 GB generados), impidiendo la reconstrucción directa de la base de datos sin descifrado y ensamblado forense.
3. **Sobre el Cumplimiento Estándar:** La articulación entre **NIST SP 800-86** (rigor en la adquisición física y preservación criptográfica) e **ISO/IEC 27042** (método científico de hipótesis rivales y cálculo de incertidumbre) permitió sostener la validez procesal de la investigación pericial, evitando una condena judicial errónea basada en suposiciones técnicas infundadas.